新手SRC漏洞挖掘经验分享

心态

SRC是一场多对多的较量，对手是研发测试运维安全等人员，也是跟自己打一场持久战。心态很重要！换个简单的话描述下，总有新功能在web应用上部署，是网站肯定就会存在漏洞，但是你既然选择了漏洞挖掘，就要做到对于好几天可能一无所获的心态调整。只有你足够坚信你自己， 就可以小有成就。

SRC的入坑潜规则

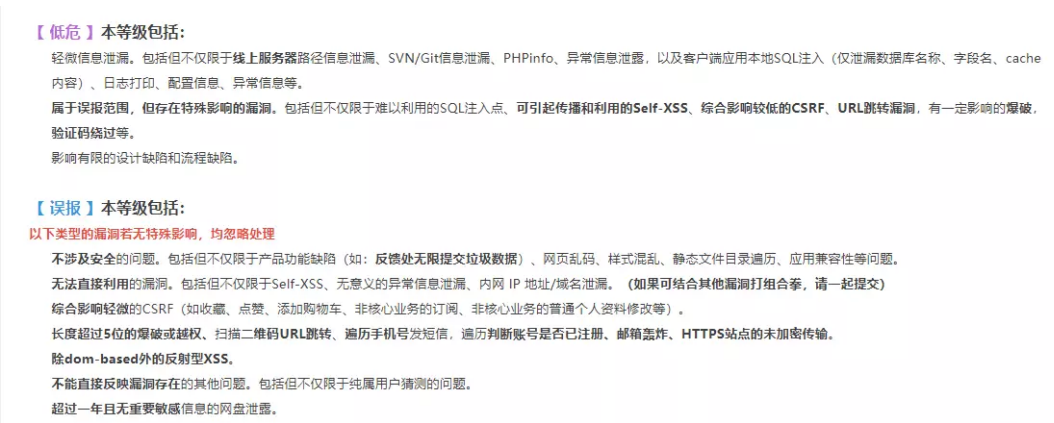
什么是SRC?

Security Response Center 安全应急响应中心

现在市面上存在了各种厂商的安全应急响应中心，大家可以自行检索

1.了解你所要提交的SRC平台规则和要求，不同的平台给出的评分标准不同

比如说这个网站根本不收反射型xss漏洞，那你却在一直尝试，岂不是浪费时间。所以第一步去读平台的漏洞评分标准。



【低危】本等级包括：

轻微信息泄漏。包括但不仅限于**线上服务器**路径信息泄漏、SVN/Git信息泄漏、PHPinfo、异常信息泄露，以及客户端应用本地SQL注入（仅泄漏数据库名称、字段名、cache内容）、日志打印、配置信息、异常信息等。

属于误报范围，但存在特殊影响的漏洞。包括但不仅限于难以利用的SQL注入点、**可引起传播和利用的Self-XSS**、**综合影响较低的CSRF**、**URL跳转漏洞**，有一定影响的**爆破**，**验证码绕过**等。

影响有限的设计缺陷和流程缺陷。

【误报】本等级包括：

以下类型的漏洞若无特殊影响，均忽略处理

不涉及安全的问题。包括但不仅限于产品功能缺陷（如：**反馈处无限提交垃圾数据**）、网页乱码、样式混乱、静态文件目录遍历、应用兼容性等问题。

无法直接利用的漏洞。包括但不仅限于Self-XSS、无意义的异常信息泄漏、内网 IP 地址/域名泄漏。 **（如果可结合其他漏洞打组合拳，请一起提交）**

综合影响轻微的CSRF（如收藏、点赞、添加购物车、非核心业务的订阅、非核心业务的普通个人资料修改等）。

长度超过5位的爆破或越权、扫描二**维码URL跳转**、**遍历手机号**发短信，**遍历判断账号是否已注册**、**邮箱轰炸**、**HTTPS站点的未加密传输**。

除dom-based外的反射型XSS。

不能直接反映漏洞存在的其他问题。包括但不仅限于纯属用户猜测的问题。

超过一年且无重要敏感信息的网盘泄露。

2.详细阅读测试范围，不要超出，会有非法测试的风险！

SRC平台会有规定的众测任务，有域名限制，超出的也不会给漏洞审核的，而且存在的非法测试的风险这里需要切记！

3.遵循安全测试规范，比如sql注入会有要求，哪些东西不能读取，最多读取多少条

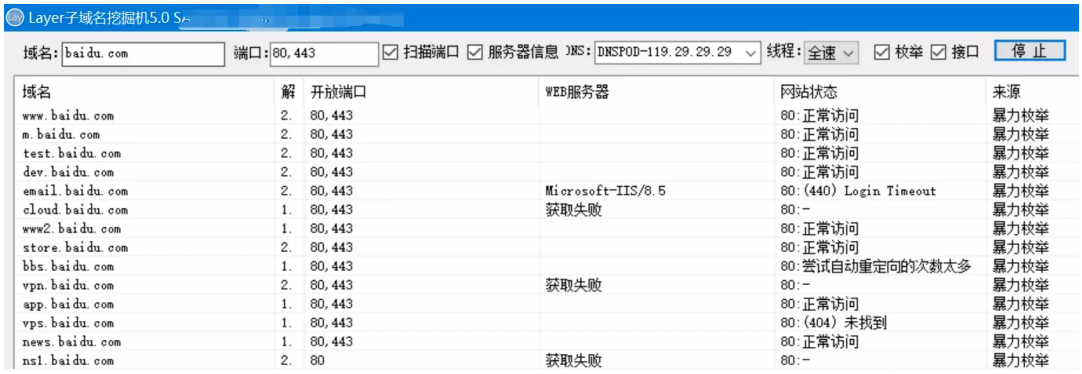
sql注入可不要脱裤啊！要不就喝茶了！这是原则问题了！！

4.看礼品啊！！！有些平台的礼品和赏金是很丰富的！！！

第一步 信息收集

在详细了解了域名范围后，就要对旗下的域名范围进行信息收集，要不你连需要测试的网站是啥都不知道，那还测试个什么劲。

这里会有一些在线的子域名收集工具（可自行百度，因为工具比较多，最适合自己的好），以及子域名挖掘机（软件类的），在各大安全社区论坛都有相关文章可以进行学习，我就是在安全客学到了很多东西哈哈哈！！！



域名	解	开放端口	WEB服务器	网站状态	来源
www.baidu.com	2.	80,443		80:正常访问	暴力枚举
m.baidu.com	2.	80,443		80:正常访问	暴力枚举
test.baidu.com	2.	80,443		80:正常访问	暴力枚举
dev.baidu.com	2.	80,443		80:正常访问	暴力枚举
email.baidu.com	2.	80,443	Microsoft-IIS/8.5	80:(440) Login Timeout	暴力枚举
cloud.baidu.com	1.	80,443	获取失败	80:-	暴力枚举
www2.baidu.com	1.	80,443		80:正常访问	暴力枚举
store.baidu.com	2.	80,443		80:正常访问	暴力枚举
bbs.baidu.com	1.	80,443		80:尝试自动重定向的次数太多	暴力枚举
vpn.baidu.com	2.	80,443	获取失败	80:-	暴力枚举
app.baidu.com	1.	80,443		80:正常访问	暴力枚举
vps.baidu.com	1.	80,443		80:(404) 未找到	暴力枚举
news.baidu.com	1.	80,443		80:正常访问	暴力枚举
ns1.baidu.com	2.	80	获取失败	80:-	暴力枚举

但信息收集不是简简单单的子域名收集，更重要的是网段，以及扩展域名，那么扩展域名怎么找呢？通常我通过域名whois来通过注册人、联系邮箱进行查找，第二就是html中的代码。ip段的收集不能说收集完了就了事了，而是需要通过IP分布来确定核心段、边缘段、云服段等等，并且需要知道目标厂商开发喜欢使用什么框架，至于怎么去找使用框架可以查看目标厂商的招聘网站看看，说不定有惊喜，在边缘段中一般会存在N台测试机器，测试机器是我们最好的突破口。因为测试机器往往不会关闭debug、并且登录账号通常为弱口令。

第二步 漏洞挖掘

参照着评定规则进行漏洞的挖掘。

常见漏洞类型:

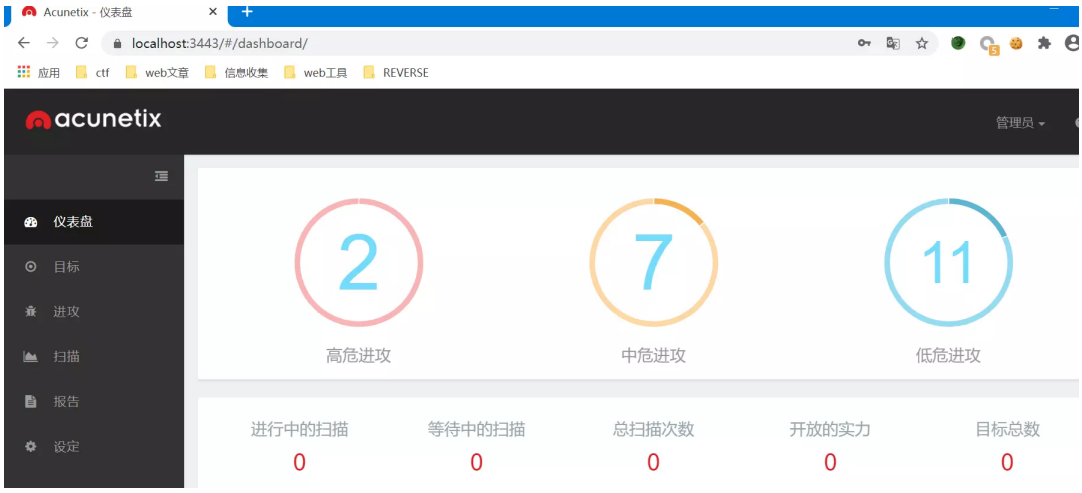
XSS、SQL注入、CSRF、权限绕过、文件上传、弱口令、代码执行等等

我们不要心机，每个都进行测试，往往会什么也得不到，一项一项来。

漏洞挖掘 1 — — — — 漏洞扫描器

关于漏洞挖掘过程中的扫描器使用问题：

网上有很多扫描器的存在，例如AWVS APPscan 等重型扫描器，但是很多网站是有防护系统的，例如安居客和58那边就会轻易的办掉你的ip，往往得不偿失，而且重型扫描器也可能会对网站造成危害，慎用。



推荐的话用BBscan这种轻量级的扫描器去扫，重点放在路径的扫描，比如说有没有403、404的站点，爆破API接口端点、路径一些的。还是不要太依赖于扫描器，强是强，但是还是自己来的踏实！

漏洞挖掘 2 — — — — 常用工具

在和榜一榜二表哥们的聊天中，他们都不怎么使用扫描器去进行测试。这里给大家推荐两个工具：

第一：BURPSUITE

（浏览器推荐Chorme 和Firefox浏览器 可以使用很多代理插件 我喜欢SwitchyOmega）

burp上可以添加很多插件实现不同的功能（表哥说玩的好也可以和xray实现自动化漏扫）

抓包改包很是方便，重放和密码爆破各种功能==神器无疑。

第二： Fiddler

Fiddler在进行并发测试的时候很舒服！！

功能和burp各有千秋！！

漏洞挖掘 3 ———— 入手点

上来对提交的一些表单（例如：意见反馈、文件上传等）要特别敏感，还有就是一些功能点（例如：付款的金额校验、修改密码的sign值替换等），进来多找功能点的进行测试，不要对着html一直有想法，毕竟不会表哥们的http协议层的攻击，新手入门可以多

在意一些数值溢出，以及接口的利用，还有就是任意文件上传这些点，慢慢在培养自己的自信心。

通过和表哥们的聊天得知，很多src大佬新手阶段都是从逻辑漏洞开始的，可以尝试一些并发的逻辑漏洞，每个网站都或多或少会存在一些的，就看你有没有善于发现的眼睛和超乎常人的耐心。

各个模块都有相对应的靶场（例如sql注入有sqli这样一些漏洞靶场进行训练）可以对自己进行漏洞利用的锻炼，不断提高经验，这里推荐 owasp虚拟机靶场，虚拟机中集成各种靶场，可以自行百度下。

漏洞挖掘 4 — — — — 提升危害

如果不是众测挖到漏洞后不建议直接提交，而是思考如何才能扩大战果，比如挖到XSS后，思考能不能拿到cookie？如果不能退一步可以不以找一个csrf将漏洞变成XSRF以此照成蠕虫？在测试机器通过弱口令进去后能不能Getshell，拿到shell后进行审计又是十几个高危。在对只有登录框界面进行测试时一定要多注意子目录以及接口。IP打开后403、404不要忽略，先扫目录，扫完了在说，往往高危会存在与许多低微的并发利用。

第三步 漏洞报告

报告不是直接把漏洞贴上去就行了，而且需要讲你是怎样发现这个资产、测试过程中遇到的问题、解决这些问题用了哪些方法、能够造成什么影响？尽可能的精简，从你是审核的角度去看待你提交的报告这样才能拿到更多的赏金或积分。（人情社会下，要互相体谅理解）

1. 标准漏洞报告格式:
   接口地址(Target):
   来源地址(Referrer):
   Payload数据包(Raw):
   利用步骤:
   危害描述:
2. 漏洞中涉及到的PoC, 需要用户提供文本型的raw包(至少要有一个接口地址)。
3. 因涉及到分享过期、敏感信息泄露的问题，白帽子在提交漏洞时不允许将报告内容传至第三方网盘第三方网盘，留空SRC报告内容。
4. 不能将不同类型，不同业务线的漏洞在同一漏洞报告中提交。

第四步 挖掘漏洞过程的一些分享

浅谈

很多人觉得难是因为没有洞察力、思考力以及大局观。什么是洞察力？简单的来说就是通过参数的变化观察页面的不同，而思考力就是结合观察到的信息去猜想后端的实现以此为基础挖掘漏洞。至于大局观不是一两句话能说清楚的，涉及到渗透的经验了。

经验从何而来?

1.可以参加一些CTF比赛，进行锻炼和升级，能很广泛的提升自己的接触面和对漏洞的认知。

2.不要企图去加一下大师傅去骚扰他们，让大师傅们分享怎么快速挖洞的技巧，没有一步登天的好事，所有的坑都需要自己去踩，每一个人都有自己的路去走。（和别人聊天前必读《提问的艺术》和善用百度）多认识一些朋友，互相分享漏洞的思路，每天去阅读些大师傅写的文章，学习骚姿势！！不断的提升自己！！

3.找大师傅们尽量听他们给的建议，或者给你的规划，而不是说一味的去问怎么挖洞，这种问题就相当于，一个小孩还不会写字，在让你教他写作文一样，毫无意义，这个过程需要自己慢慢的积累和学习，而不是让别人喂，来让别人施舍，只会让别人看不起自己！

4.一定要有自信心，对于我们平常使用的东西，敢于发出挑战，比如让你挖百度的漏洞，你自己从心理上都把自己吓跑了（诶呀 我天天用的东西，怎么会存在漏洞呢），摆正心态，不要抱着一定会被审核通过的想法，被忽略很正常。

趣谈

之前运气好，挖到的一个洞的思路就分享给大家，首先是通过一个很微小的信息泄露在http的响应头中，找到了他们使用的cms版本号，后来通过搜索市面上的漏洞，发现最新版的问题都不存在了，后来又下载了最新的源码进行了代码审计，然后正好那段时间在学，就发现了个sql注入点。

总结

这篇文章可能没有像别的大师傅写出来很炫酷的姿势，希望对和我一样的新入门的朋友能产生一些激励，带来新的思路，因为交src总有被忽略的时候，不要灰心丧气，年轻的程序员从来不缺重头再来的勇气！加油！！希望可以有所帮助！！

所以没有人的成功是偶然的，要多提升自己的能力，而不是想着去如何如何赚钱，赚钱固然很好，但赚钱当你成功之后是顺带的事情，把眼光放远，我们才能走的更远！！